Prioritized Recommendations and Remediation Roadmap

This section provides prioritized recommendations for addressing the identified cybersecurity gaps at XYZ Technologies, along with a proposed remediation roadmap. Recommendations are categorized by assessment domain and prioritized based on the risk evaluation.

Prioritization Key

- **Critical:** Immediate action required. These issues pose the highest risk to the organization and should be addressed within 0-30 days.
- **High:** Urgent action required. These issues present significant risk and should be addressed within 30-90 days.
- **Medium:** Important action. These issues should be addressed within 90-180 days.
- **Low:** Recommended action. These issues can be addressed as part of continuous improvement efforts, within 180+ days.

Recommendations by Assessment Domain

1. Existing Security Policies and Standards

- **Recommendation (Critical):** Review and update all existing security policies and standards to align with current threats, technologies (e.g., Microsoft 365, hybrid workforce), and regulatory requirements. Establish a formal policy review cycle.
  - **Remediation Steps:**
    1. Designate a policy owner/team.
    2. Conduct a gap analysis against ISO 27001 and NIST CSF.
    3. Draft updated policies and standards.
    4. Obtain management approval.
    5. Communicate new policies to all employees.

2. Governance Structure

- **Recommendation (High):** Develop and formalize an ISMS scope document to clearly define the boundaries and applicability of the information security management system.

- **Remediation Steps:**
    1. Identify critical assets and business processes.
    2. Define organizational boundaries and interfaces.
    3. Document the ISMS scope and obtain stakeholder approval.
- **Recommendation (High):** Establish a formal security steering committee with clear terms of reference, responsibilities, and regular meeting cadences to provide strategic oversight and decision-making for information security initiatives.
    - **Remediation Steps:**
        1. Identify key stakeholders for committee membership.
        2. Define committee charter, roles, and responsibilities.
        3. Schedule regular meetings and establish reporting mechanisms.

3. Asset Ownership and Classification

- **Recommendation (Medium):** Implement a robust asset inventory and classification program. Clearly define asset owners and their responsibilities for protecting information assets.
    - **Remediation Steps:**
        1. Deploy an asset discovery and inventory tool.
        2. Develop an information classification scheme.
        3. Assign asset ownership and document responsibilities.

4. Security Roles and Responsibilities

- **Recommendation (Critical):** Implement mandatory, regular security awareness training for all employees, tailored to their roles and responsibilities. Include specific modules on phishing, social engineering, and data handling.
    - **Remediation Steps:**
        1. Select a security awareness training platform.
        2. Develop or customize training content.
        3. Implement mandatory training with tracking and reporting.
        4. Conduct regular phishing simulations.

5. Risk Management Processes

- **Recommendation (Critical):** Establish and document a formal information security risk management methodology, aligned with recognized frameworks (e.g., ISO 27005,

NIST SP 800-30). This should cover risk identification, assessment, treatment, monitoring, and communication.

- **Remediation Steps:**
  1. Adopt a recognized risk management framework.
  2. Define risk appetite and criteria.
  3. Implement a risk register and conduct initial risk assessments.
  4. Establish a continuous risk monitoring process.

- **Recommendation (Critical):** Implement a formal vendor risk management program, including due diligence for new vendors, contractual security clauses, and ongoing monitoring of third-party security posture, especially for payment service integrations.
  - **Remediation Steps:**
    1. Develop a vendor risk assessment questionnaire.
    2. Integrate security requirements into procurement contracts.
    3. Implement a process for periodic vendor security reviews.
    4. Utilize third-party risk assessment tools if necessary.

6. Incident Escalation Procedures

- **Recommendation (High):** Conduct regular testing and drills of the Incident Response Plan (IRP), including tabletop exercises and simulated incidents, to ensure its effectiveness and identify areas for improvement.
  - **Remediation Steps:**
    1. Schedule regular IRP testing exercises.
    2. Document lessons learned and update the IRP.
    3. Train incident response team members.

7. Access Management and Privileged Account Controls

- **Recommendation (Critical):** Eliminate all shared administrative accounts. Implement individual accounts with appropriate access controls and logging.
  - **Remediation Steps:**
    1. Identify all shared admin accounts.
    2. Provision individual accounts for all users.
    3. Deactivate shared accounts and monitor for new instances.

- **Recommendation (Critical):** Implement mandatory quarterly access reviews for all user accounts, especially privileged accounts and those with access to sensitive data, to ensure least privilege is maintained.
  - **Remediation Steps:**
    1. Establish a schedule for access reviews.
    2. Define roles and responsibilities for conducting reviews.
    3. Implement an access review tool or process.
    4. Document review outcomes and remediation actions.
- **Recommendation (Critical):** Deactivate all 14 inactive accounts. Implement an automated process for identifying and deactivating dormant accounts.
  - **Remediation Steps:**
    1. Verify inactivity of accounts.
    2. Deactivate identified inactive accounts.
    3. Implement an automated dormant account detection and deactivation policy.
- **Recommendation (High):** Reduce the number of users with Global Administrator privileges to the absolute minimum necessary (e.g., 2-3 break-glass accounts). Implement a just-in-time (JIT) access model for elevated privileges.
  - **Remediation Steps:**
    1. Identify current Global Admin holders.
    2. Implement a Privileged Access Management (PAM) solution or JIT access.
    3. Revoke unnecessary Global Admin privileges.
- **Recommendation (Critical):** Enable Multi-Factor Authentication (MFA) for all 22 privileged accounts immediately. Extend MFA to all user accounts, especially for access to Microsoft 365 and critical systems.
  - **Remediation Steps:**
    1. Prioritize enabling MFA for all privileged accounts.
    2. Roll out MFA for all other user accounts.
    3. Monitor MFA adoption and enforcement.

8. Vendor and Third-Party Security Practices

- **Recommendation (Critical):** Immediately disable Legacy TLS 1.0 on the payment portal and enforce a minimum of TLS 1.2. Conduct a comprehensive review of all public-facing services for deprecated protocols and ciphers.

- **Remediation Steps:**
    1. Configure payment portal to use TLS 1.2 or higher.
    2. Test payment portal functionality after changes.
    3. Scan all public-facing services for deprecated protocols.

Operational/Technical Gaps

- **Recommendation (Critical):** Implement a robust Secure Software Development Lifecycle (SSDLC) that includes code reviews, automated security testing (SAST/DAST), and a formal change management process to prevent direct pushes to production.
    - **Remediation Steps:**
        1. Integrate security gates into the CI/CD pipeline.
        2. Implement mandatory code review processes.
        3. Train developers on secure coding practices.
- **Recommendation (Critical):** Establish a regular and documented backup testing schedule to ensure data recoverability. This should include periodic restoration drills to validate backup integrity and recovery procedures.
    - **Remediation Steps:**
        1. Define backup testing frequency and scope.
        2. Conduct regular restoration tests.
        3. Document test results and address any failures.
- **Recommendation (Critical):** Implement a rigorous vulnerability management program to identify, prioritize, and remediate critical vulnerabilities within 30 days. This includes regular scanning, patch management, and configuration hardening.
    - **Remediation Steps:**
        1. Establish a vulnerability scanning schedule.
        2. Prioritize remediation based on risk.
        3. Implement a patch management system.
        4. Address the 17 critical vulnerabilities immediately.
- **Recommendation (Critical):** Update the public-facing server running an outdated Apache version to a currently supported and secure version. Implement a continuous monitoring process for software versions and end-of-life dates.
    - **Remediation Steps:**
        1. Plan and execute the Apache upgrade.

2. Test server functionality post-upgrade.
3. Implement software version tracking and update policies.